

Distributed Denial of Service (DDoS) Attacks

Outline

- (D) Denial-of-Service concepts
- Things you can do to defend yourself
- Things others can do to help you

What is a Denial-of-Service Attack?

- A Denial-of-Service (DoS) attack denies the normal usage of a service.
- The target might want to use the service or want to provide the service:
 - An attacker might overload the mail server so the employees cannot access their mail.
 - An attacker might overload the web server of a company so (potential) customers cannot access important information.
- So for this talk, we will call the affected service the “victim”.

“Real-World” Analogy

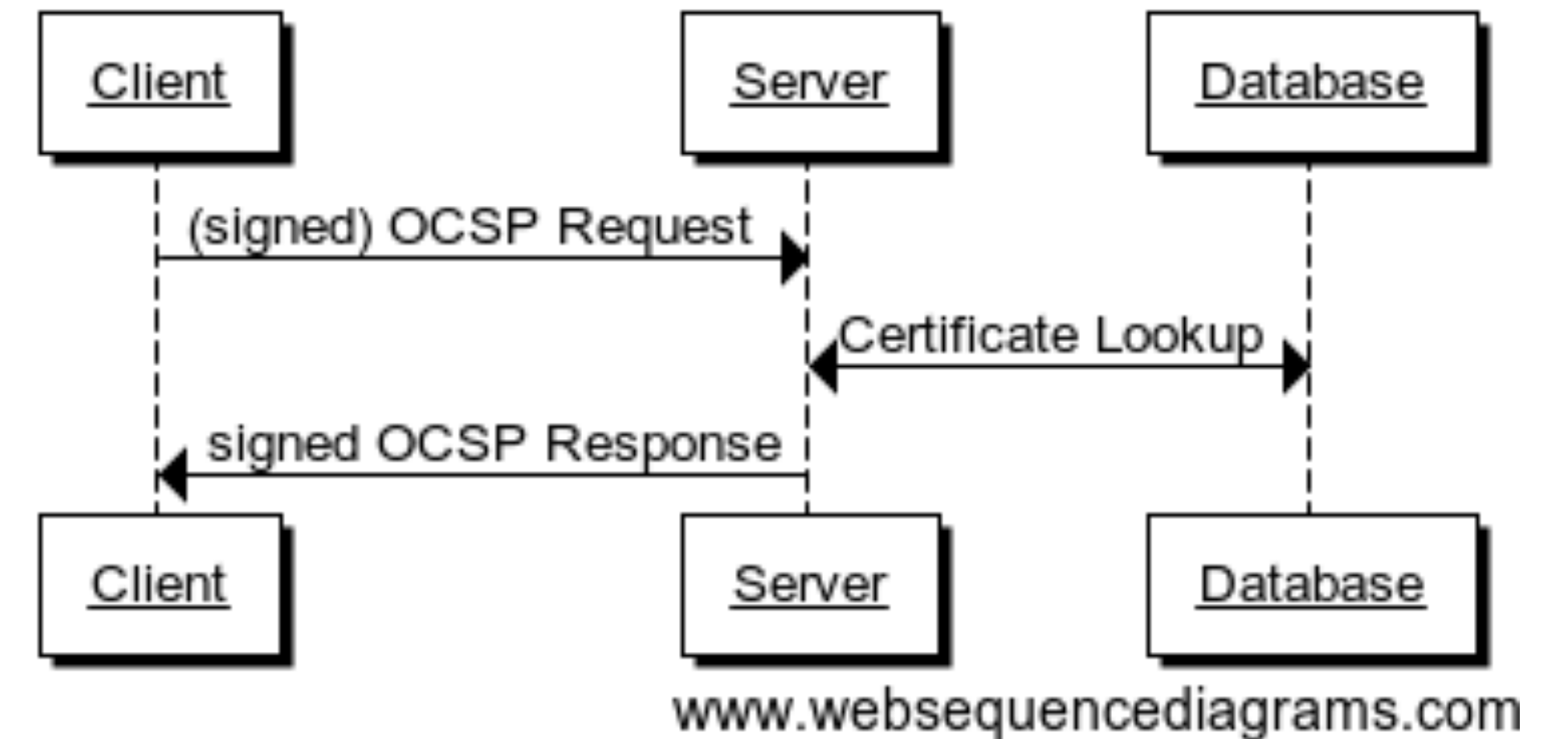
- By way of analogy, consider a vaccination center as the service that is attacked:
 - An attacker might want to deny people the benefits of vaccination. In this case, the intended targets of the attack are the patients.
 - The intention might also be to make the government look bad because it cannot even make sure the people get vaccinated on time. In this case, the intended target is the government.

How Service Can Be Denied ?

- “Denial of Service” is a very generic concept and does not specify any technical details at all. (At least) the following layers can be attacked:
 - Metadata/prerequisite data,
 - Network information,
 - Network components and resources,
 - Systems and system resources,
 - Applications and application resources.

Metadata/Prerequisite Data

- Any information that is required to use a particular service.
- Examples:
 - DNS resolution,
 - NTP synchronisation,
 - OCSP lookups,
- Vaccination center: **Published location**



Network Information

- Necessary information for network traffic to reach the victim service.
- Examples:
 - Routing information,
 - Peering relationships
- Vaccination center: **Road signs**

Network Components and Resources

- Components and resources that are necessary for network traffic to reach the victim system.
- Components can be crashed, resources can be exhausted.
- Examples:
 - Link bandwidth,
 - Router Forwarding Information Base capacity,
 - Firewall connection state table capacity.
- Vaccination center: **Road capacity**

Systems and System Resources

- Victim systems and resources on them that are necessary to provide the service.
- Systems can be crashed, resources can be exhausted.
- Examples:
 - Memory,
 - CPU capacity,
 - Disk drive availability.
- Vaccination center: **Parking lot capacity**

Applications and Application Resources

- Victim applications and resources in them that are necessary to provide the victim service.
- Applications can be crashed, resources can be exhausted.
- Examples:
 - Application threads,
 - Connection handles,
 - Buffer capacity.
- Vaccination center: **Vaccination booth capacity**

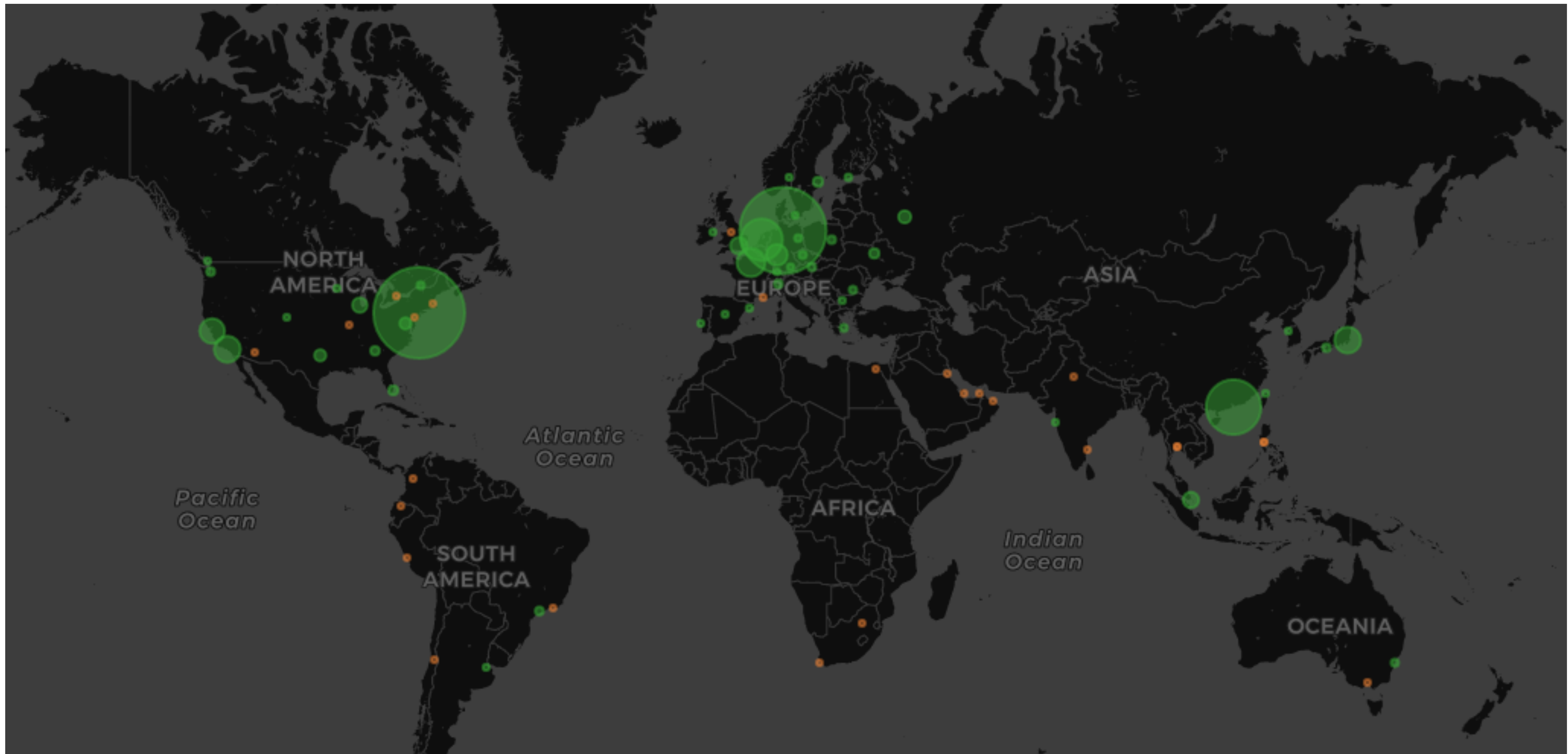
Mirrors & Magnifying Glasses

- Observation: To avoid attribution and make defense harder, an attack should (appear to) come from many sources simultaneously.
- Idea: Use third-party services that not only **reflect**, but also **amplify**.
- Examples:
 - memcached (amp factor: up to ~50000)
 - NTP (amp factor: up to ~500)
 - DNS (amp factor: up to ~50)

Memcached

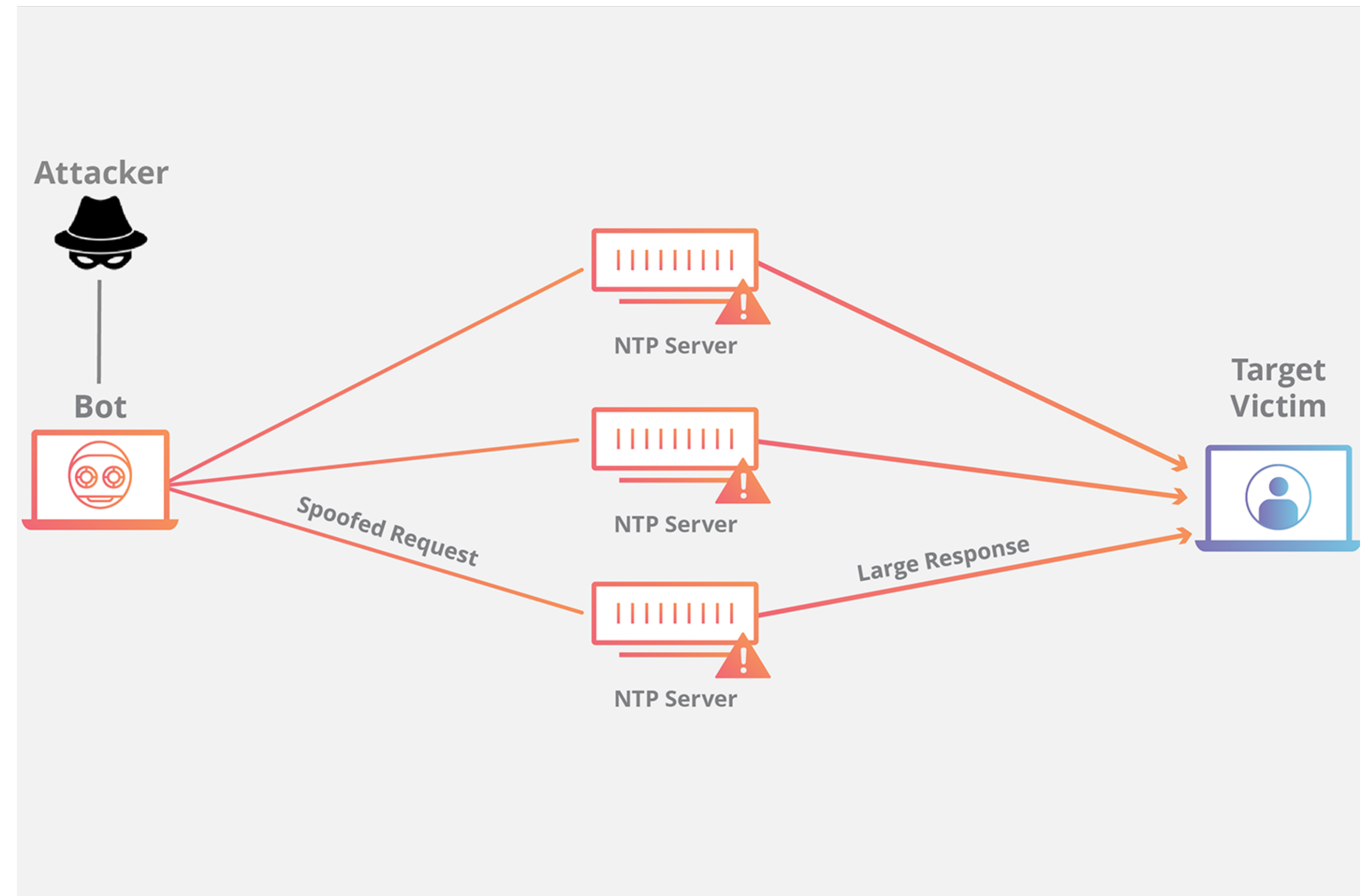
- A memcached attack occurs in 4 steps:
 - An attacker implants a large payload* of data on an exposed memcached server.
 - Next the attacker spoofs an HTTP GET request with the IP address of the targeted victim.
 - The vulnerable memcached server that receives the request, which is trying to be helpful by responding, sends a large response to the target.
 - The targeted server or its surrounding infrastructure is unable to process the large amount of data sent from the memcached server, resulting in overload and denial-of-service to legitimate requests.

Memcached



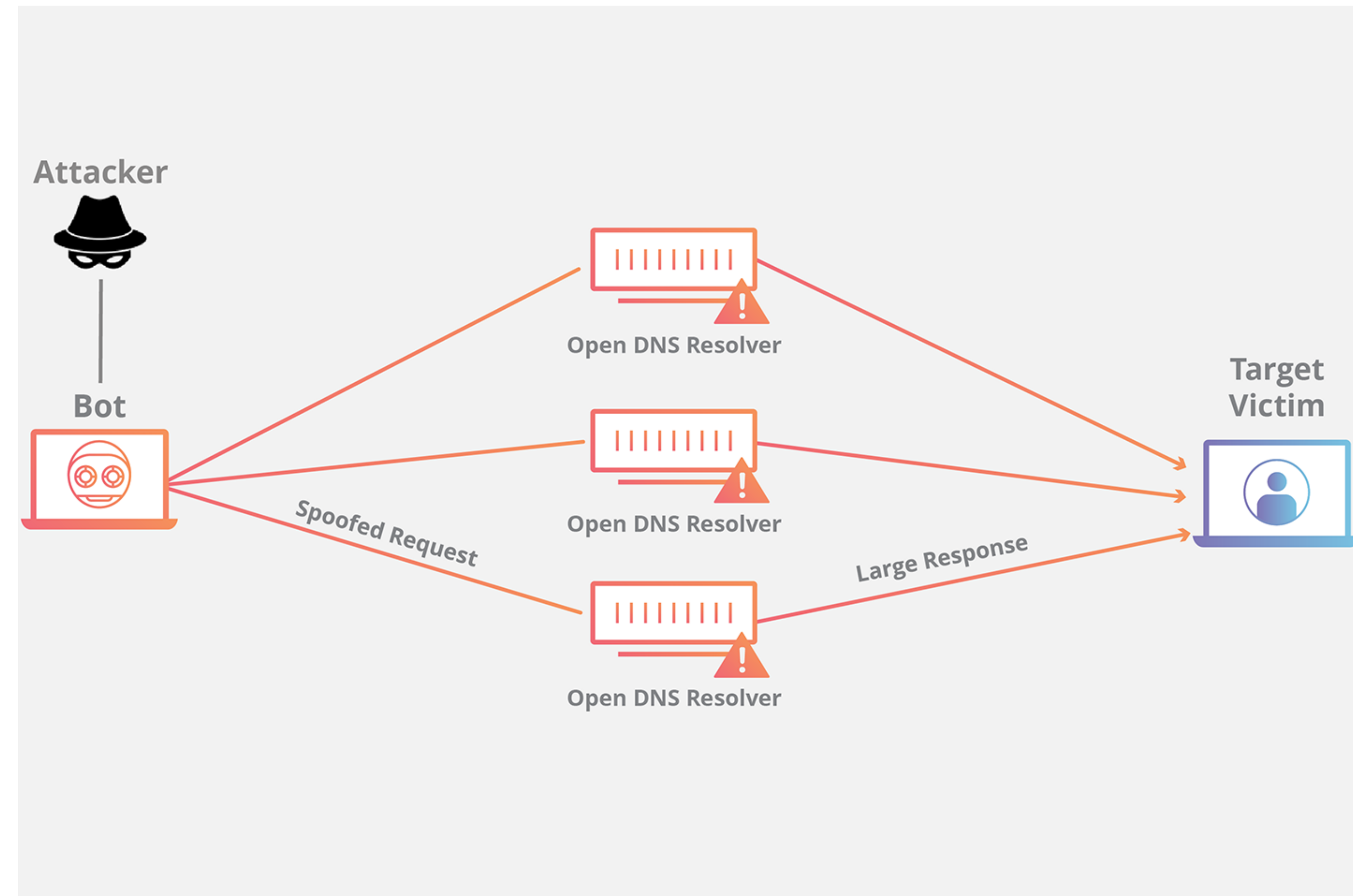
NTP

- The attacker uses a botnet to send UDP packets with spoofed IP addresses to a NTP server which has its monlist command enabled. The spoofed IP address on each packet points to the real IP address of the victim.
- Each UDP packet makes a request to the NTP server using its monlist command, resulting in a large response.
- The server then responds to the spoofed address with the resulting data.
- The IP address of the target receives the response and the surrounding network infrastructure becomes overwhelmed with the deluge of traffic, resulting in a denial-of-service.

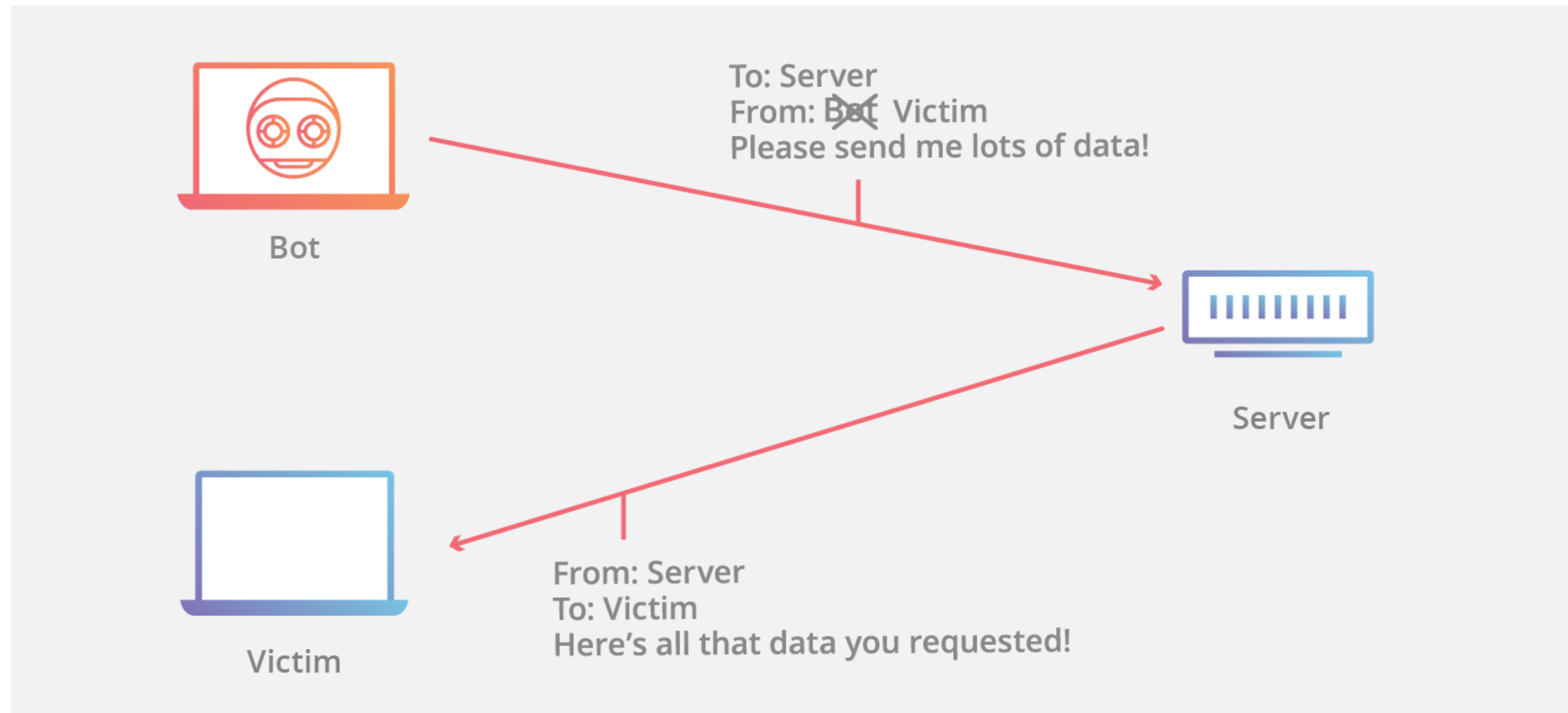


DNS

- The attacker uses a compromised endpoint to send UDP packets with spoofed IP addresses to a DNS recursor. The spoofed address on the packets points to the real IP address of the victim.
- Each one of the UDP packets makes a request to a DNS resolver, often passing an argument such as “ANY” in order to receive the largest response possible.
- After receiving the requests, the DNS resolver, which is trying to be helpful by responding, sends a large response to the spoofed IP address.
- The IP address of the target receives the response and the surrounding network infrastructure becomes overwhelmed with the deluge of traffic, resulting in a denial-of-service.



Spoofing



Crowdsourcing

- Observation: Amplification attacks are also fairly hard to pull off nowadays.
- Idea: Use hacked third-party resources for more direct DoS attacks instead. These computers are called **bots** or **zombies**; a “network” of bots under central control is called a **botnet**.
- Examples:
 - Dark Nexus
 - Smominru
 - Mirai

Bots as a Service

- Creating a botnet is very hard and requires skill, tools and time, which most attackers do not have.
- Skilled hackers specialize in creating botnets (**botherders**) and rent botnets to attackers for money.
- Additional toolsets (**booters**) to make launching attacks easier are also helpful to help the attackers.

Attacker Motivation

- Common attacker types and their objectives:
 - Criminals: Extorting ransom from the target for **financial gain**.
 - Hacktivists: Punishing a target for **ideological or even personal reasons**.
 - Nation-states or equivalent: Disrupting a target for **political benefit**.

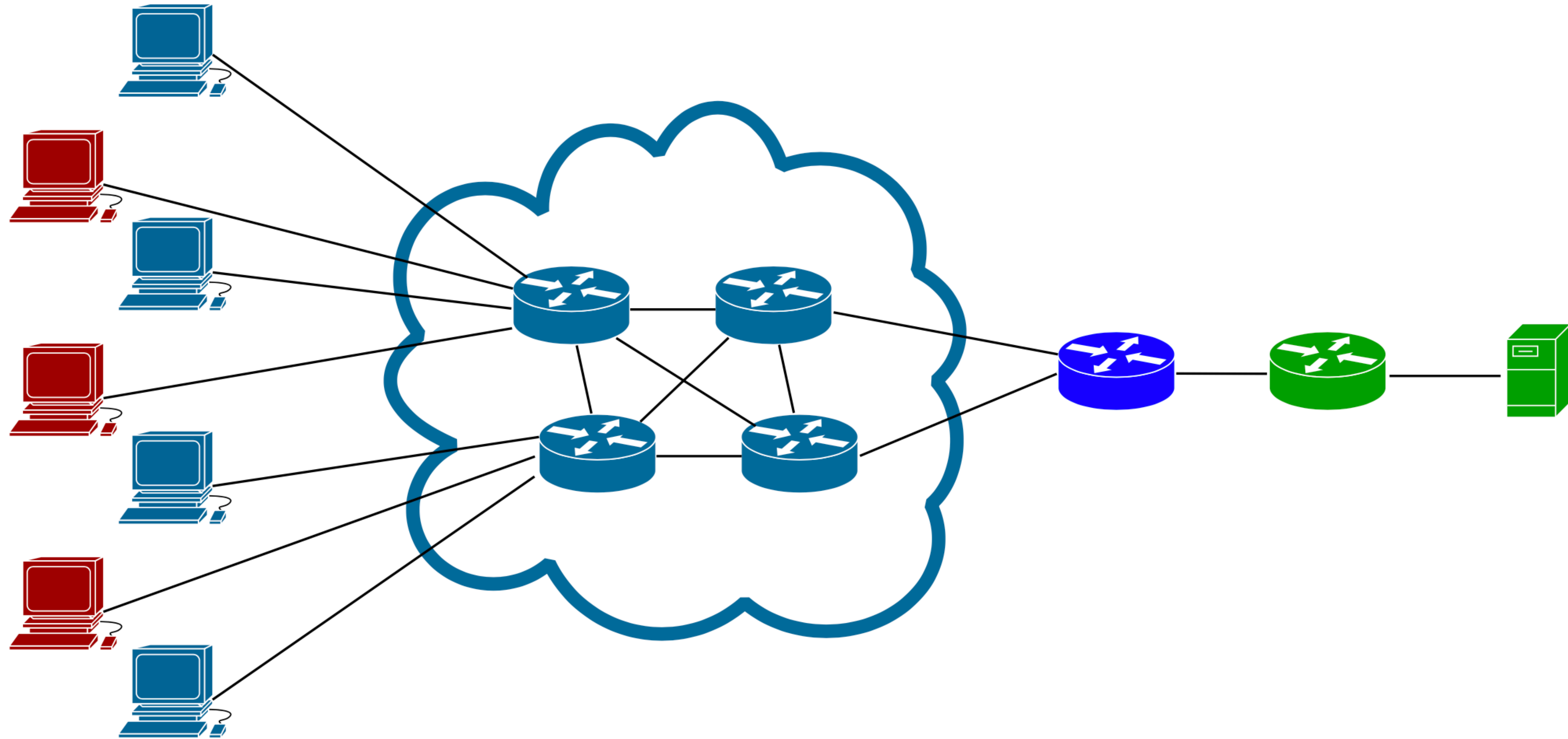
Defensive Thinking

- Depending on the particular attack and skill level, **DoS attacks** are a **very serious threat**.
- It is very hard or even **impossible** for the victim to **defend** itself against DDoS attacks **without external help**.
- **Attribution** is rather **difficult**.
- DDoS attacks can have rather nasty consequences for the victim:
 - Immediate: **Critical services** with real-life impact.
 - Financial: Dealing with the attack, restoring services, **ransom**, loss of revenue.
 - Reputation: Being perceived as **incompetent** or helpless.

Red Alert, Shields Up!

- A Denial-of-Service (DoS) attack denies the normal usage of a service.
- A Distributed DoS attack is a DoS attack simultaneously coming from many sources.
- We assume you are running the victim service and have decided you are under attack.
- You have root access to the machine (sysadmin).
- What You Can Do When Under Attack ?

General DDOS Overview



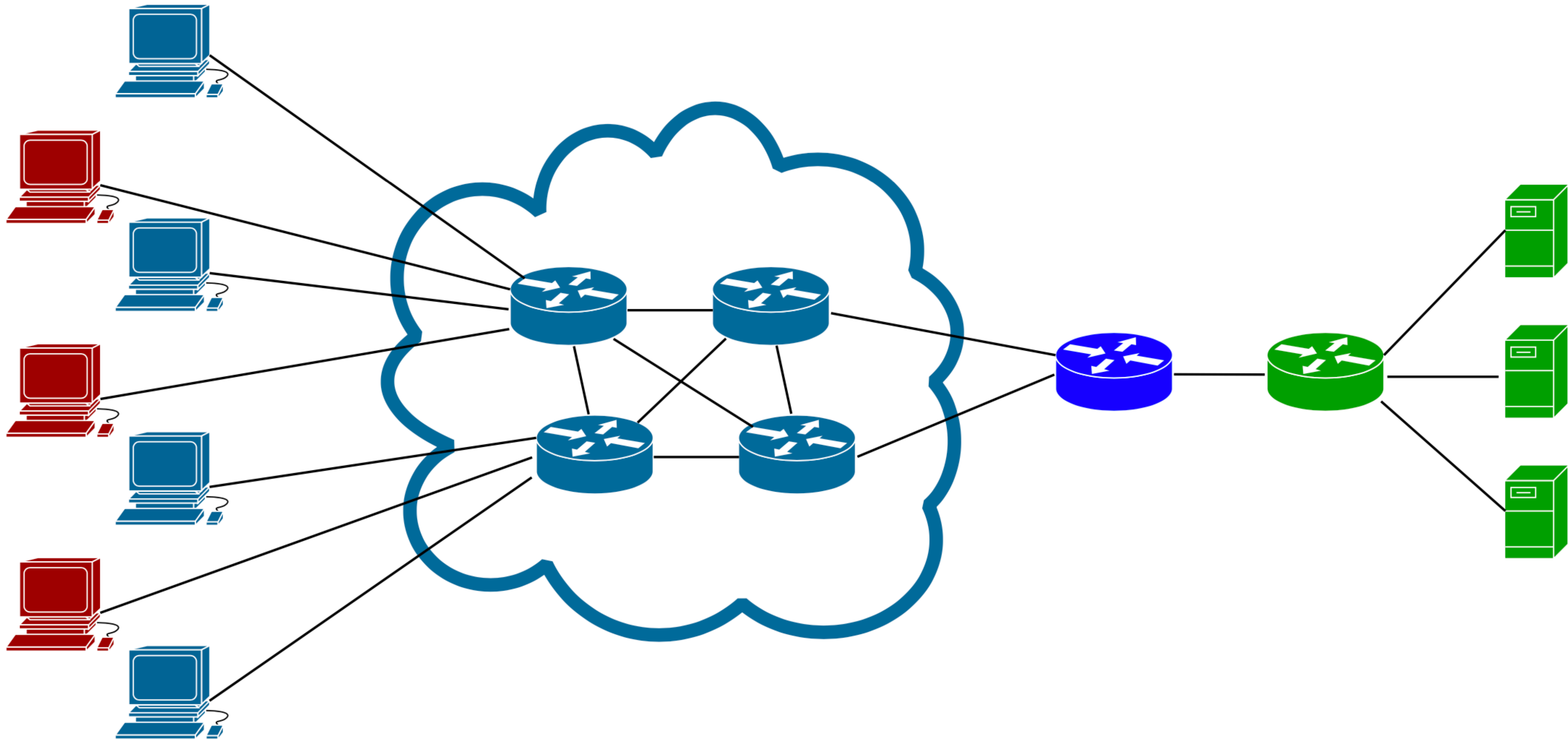
How to Respond ?

- In order to apply an effective countermeasure, it is necessary to **identify** the **layer** that is actually being **attacked**!
- For a given attack, there may be a number of effective countermeasures on a variety of levels.
- Most countermeasures require **preparation**, and all countermeasures are easier to implement with **preparation**.

Application and System Resources

- In some ways the easiest to defend:
 - Best chance of truly understanding traffic
 - Make sure the system is properly sized (CPU, RAM, HDD, Gbit/sec)
 - Start additional system instances (backup sites)
 - Restrict or rate-limit traffic (connections/ip, requests/ip)
 - “Memcache” responses
 - Cut rarely used but expensive services when above specified system load

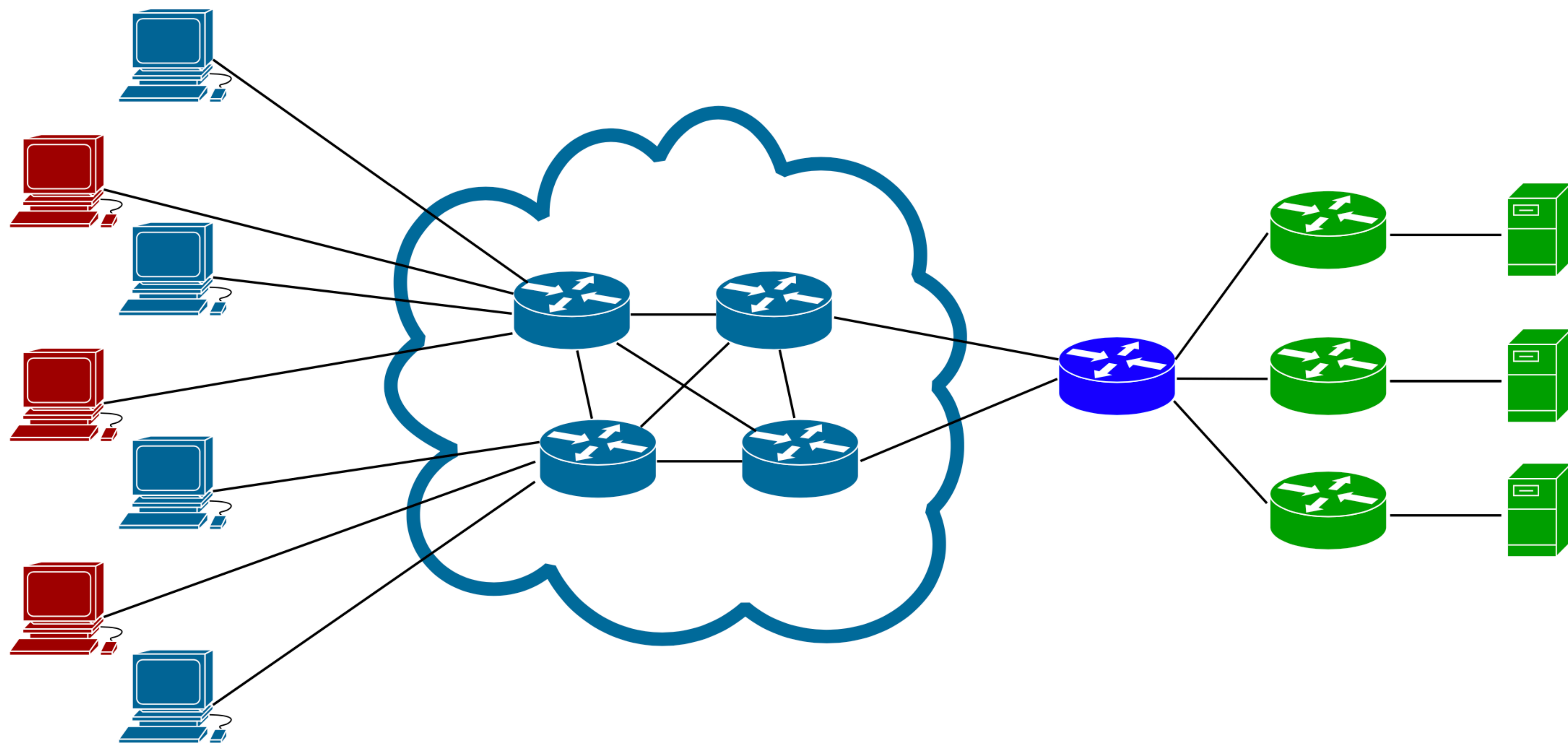
Local Mitigation



Network Components and Resources

- Defense on this level is a different game and very problematic:
 - Adding networking resources or components ad-hoc is often very hard or impossible,
 - Attacks often take down entire sites, severely limiting response capabilities, collateral damage is often substantial,
 - Affected components or resources only partially under your control, if at all!
- Possible courses of action:
 - Restrict or rate-limit traffic (e. g., the rate of inbound ICMP packets)
 - Move service to backup site with different address, preferably different ISP, and update DNS etc.
 - Blackhole traffic based on traffic sources (ips, countries, etc.)

Off-Site Mitigation



How others can help you: ISP

- Uniquely, your ISP can blackhole traffic before it becomes a problem for your uplink
 - Blackhole routing is the name of the game
 - Preferably as much upstream as possible
 - This will take the victim service offline
- Keep key connections with static explicit routing
 - Much easier if you have discussed this beforehand with your ISP

DDOS Mitigation Providers

- Commercial companies that offer “cleaning” of network traffic. Two flavors: Always-on and On- demand.
 - **Always-on**: All traffic is permanently routed through the mitigation provider resources. Adds latency because of longer routes.
 - **On-demand**: Traffic is re-routed through mitigation provider resources when an attack is detected. Takes a bit of time to switch over, and mitigation provider might be bypassed by a clever attacker.
- CloudFlare

Content Delivery Networks (CDN)

- CDNs provide decentralized service delivery:
 - Primary benefit are quicker deliveries because the CDN servers are “closer” to the client, topologically speaking.
 - But this also means that it is very hard to attack the service as a whole because there are a lot of delivery endpoints.
 - Only helps if deployed beforehand

DDOS Mitigation Providers / CDN

